

Acme Corporation — Internal Policy Handbook

Effective Date: January 2026 · Internal Use Only · Version 4.2

1. Data Retention Policy

All customer transaction records must be retained for a minimum of seven (7) years from the date of the transaction, in accordance with financial regulatory requirements. Records include but are not limited to: invoices, payment confirmations, refund logs, and account modification histories.

Employee records, including performance reviews and disciplinary actions, must be retained for the duration of employment plus five (5) years following termination or resignation. Tax-related employee documents follow a separate seven (7) year retention schedule as mandated by federal tax law.

After the applicable retention period expires, records must be securely destroyed using an approved data destruction method. Physical documents must be shredded using a cross-cut shredder; digital records must be permanently deleted using DoD 5220.22-M compliant wiping software, not simple file deletion.

Backup copies of any retained data are subject to the same retention and destruction schedule as the primary record. IT Operations is responsible for ensuring backup rotation policies do not inadvertently extend retention beyond the mandated period.

2. Access Control Procedures

Access to customer financial data is restricted on a least-privilege basis. Employees may only access records directly relevant to their assigned job function. Requests for expanded access must be submitted in writing to the Data Governance team and approved by both the requesting employee's manager and the Data Protection Officer.

All access to production databases containing personally identifiable information (PII) requires multi-factor authentication (MFA). Single-factor authentication is not permitted under any circumstances for systems classified as Tier 1 (Critical) or Tier 2 (Sensitive).

Access reviews are conducted quarterly. Any account showing no login activity for 90 consecutive days will have its access automatically revoked and must be re-requested through the standard approval workflow described above.

Privileged access (administrator-level) to any production system requires a documented business justification, time-bound access grants not exceeding 30 days, and mandatory session recording for audit purposes.

3. Incident Response Timeline

Upon discovery of a suspected security incident, the discovering employee must notify the Security Operations Center (SOC) within one (1) hour via the designated incident hotline or the internal incident reporting portal.

The SOC must triage and classify the incident severity (Critical, High, Medium, Low) within two (2) hours of the initial report. Critical and High severity incidents trigger immediate activation of the Incident Response Team (IRT).

If an incident is confirmed to involve unauthorized access to customer PII, the Legal and Compliance team must be notified within four (4) hours, and a determination on regulatory breach notification obligations must be made within twenty-four (24) hours of confirmation.

A full post-incident review, including root cause analysis and remediation action items, must be completed and documented within ten (10) business days of incident closure. This review is presented to the Risk Committee at its next scheduled meeting.

4. Remote Work and Equipment Policy

Employees approved for remote work must use only company-issued laptops with full-disk encryption enabled and endpoint detection and response (EDR) software installed and actively reporting to the central security console.

Use of personal devices to access company email, file storage, or internal applications is prohibited unless the device is enrolled in the company's Mobile Device Management (MDM) program and meets minimum security baseline requirements.

Remote employees must connect to internal systems exclusively through the company VPN. Split-tunneling configurations that route any internal traffic outside the VPN tunnel are not permitted without an documented exception from IT Security.

5. Expense Reimbursement Guidelines

Business travel expenses must be submitted within thirty (30) days of the expense being incurred. Expenses submitted after sixty (60) days will not be reimbursed except in cases of documented extenuating circumstances approved by a Vice President or above.

Meal reimbursements are capped at \$75 per day for domestic travel and \$100 per day for international travel, inclusive of tips. Itemized receipts are required for any single expense exceeding \$25; credit card statements alone are not sufficient documentation.

Airfare must be booked in economy class for flights under six (6) hours. Business class is permitted for flights exceeding six (6) hours with Director-level or above approval obtained prior to booking.